

Incident Response Plan: Ransomware Attack

Purpose:

This plan provides steps to detect, contain, eradicate, and recover from a ransomware attack to minimize operational disruption and data loss.

Scope:

Applies to all organizational systems, networks, and devices.

Security Incident

Type: Ransomware

Ransomware is malware that encrypts files, making them inaccessible until a ransom is paid. Impact includes data loss, operational downtime, and potential financial or reputational damage.

Detection

Method: Endpoint Detection and Response (EDR) tools and monitoring Indicators of Compromise (IOCs).

Signs of infection:

- Files with unusual extensions or encryption
 - Ransom notes appearing on screens
 - Antivirus/antimalware alerts
-

Containment Strategy

1. Isolate infected systems from the network immediately.

2. Disable shared drives and network connections.
 3. Block malicious IPs and email sources.
 4. Notify IT security team and leadership.
-

Eradication Steps

1. Identify the ransomware strain using security tools.
 2. Delete or quarantine infected files.
 3. Remove malware using updated antivirus/antimalware solutions.
 4. Apply security patches to prevent reinfection.
-

Recovery Steps

1. Restore files from clean backups.
2. Rebuild systems if backups are unavailable.
3. Verify integrity of restored data.
4. Gradually reconnect systems to the network, monitoring for reinfection.
5. Inform stakeholders of recovery status.

Security Policy Document

1. Purpose

The purpose of this security policy is to establish clear rules and guidelines that protect organizational systems, data, and users from security threats. This document also outlines incident response procedures and demonstrates how these measures maintain the **CIA Triad** of information security.

2. Security Rules and Guidelines

Rule 1: Strong Authentication Requirements

- All user accounts must use strong passwords (minimum 12 characters, including letters, numbers, and special characters).
- Multi-Factor Authentication (MFA) is mandatory for remote access and administrative accounts.

Rule 2: Data Protection and Handling

- Sensitive data must be encrypted both in transit (using TLS/SSL) and at rest.
- Employees must not store sensitive data on personal devices or unapproved cloud services.

Rule 3: Acceptable Use of Technology

- Company devices are to be used strictly for business purposes.
 - Unauthorized software installation is prohibited.
 - Employees must not disable or bypass security controls such as antivirus, firewalls, or monitoring tools.
-

3. Incident Response Plan

Step 1: Identification

- Detect suspicious activity through monitoring systems (e.g., unusual login attempts, malware alerts, or data access anomalies).

Step 2: Containment

- Isolate affected systems from the network to prevent spread.
- Block malicious IP addresses, accounts, or applications.

Step 3: Eradication

- Remove malicious software or compromised accounts.
- Patch vulnerabilities that were exploited.

Step 4: Recovery

- Restore systems from clean backups.
- Reconnect systems carefully while monitoring for reinfection.

Step 5: Lessons Learned

- Conduct a post-incident review.
 - Update security controls and employee training to prevent future breaches.
-

4. Maintaining the CIA Triad

Confidentiality

- Encryption, access controls, and MFA protect sensitive information from unauthorized access.

Integrity

- Patching vulnerabilities, restricting software installation, and enforcing monitoring ensure that data is not altered or corrupted by unauthorized users.

Availability

- Incident response and recovery procedures ensure that systems and services are restored quickly after a breach, minimizing downtime.

The tool provides multiple modes of encryption and decryption such as its performance.

For more info on AES encryption, visit [this explanation on AES Encryption](#)

AES Encryption

Enter Plain Text to Encrypt
My name is Matt and this is my encryption submission.

Select Cipher Mode of Encryption
CBC

Select Padding
PKCS5Padding

Enter IV (Optional)
Enter initialization vector

Key Size in Bits
128

Enter Secret Key
aesEncryptionKey

Output Text Format ☒ Base64 ☐ Hex

Encrypt

AES Encrypted Output
Jk9oRb6Nm7Be0ieEMc+MD9x4qmQc7K9AT8NSq900SZKHw\$ReAPbFzyVN8OqONyh2GXWLdudU91Sk0hrNFH2NuQ==

AES Decryption

AES Encrypted Text
Jk9oRb6Nm7Be0ieEMc+MD9x4qmQc7K9AT8NSq900SZKHw\$ReAPbFzyVN8OqONyh2GXWLdudU91Sk0hrNFH2NuQ==

Select Cipher Mode of Decryption
CBC

Select Padding
PKCS5Padding

Enter IV Used During Encryption(Optional)
Enter initialization vector

Key Size in Bits
128

Enter Secret Key used for Encryption
aesEncryptionKey

Output Text Format ☒ Plain-Text ☐ Base64

Decrypt

AES Decrypted Output
My name is Matt and this is my encryption submission.

RSA Key Pair Generator

Online RSA Encrypt Decrypt

Encrypt Image Online

Online File Encrypt Decrypt

Online Text Encrypt Decrypt

Download

Extension for Mac (Free)

Only 2 Steps

Click "Download"

Add Safe Search

SAFE SEARCH

Legal and Ethical Compliance in Incident Response

1. Relevant Laws and Regulations

1. General Data Protection Regulation (GDPR)

- Applies to organizations handling personal data of EU citizens.
- Requires notification of data breaches to supervisory authorities within **72 hours**.
- Enforces principles of transparency, accountability, and data minimization.

2. Health Insurance Portability and Accountability Act (HIPAA)

- Applies to U.S. healthcare organizations and their business associates.
- Requires protection of **Protected Health Information (PHI)** from unauthorized access or disclosure.
- Mandates breach notification to affected individuals and regulators.

*(If your organization is not in healthcare or the EU, substitute laws like **GLBA** for financial data, or **CCPA** for California consumer data protection. For coursework, these two are widely recognized.)*

2. Ethical Considerations

Ethical Principle: Honesty and Transparency

- Organizations have an ethical duty to notify stakeholders (employees, customers, or patients) if their personal data may have been compromised.
 - Concealing or delaying breach disclosure undermines trust and could result in further harm to affected individuals.
-

3. Compliance Within the Incident Response Plan

- **Identification & Containment:** By quickly isolating threats, the plan ensures compliance with the legal duty to mitigate damage to personal data.
 - **Eradication & Recovery:** Protecting systems and restoring data integrity aligns with HIPAA's requirement for safeguarding health data and GDPR's principle of data accuracy.
 - **Breach Notification:** The plan includes notifying stakeholders and authorities promptly, which fulfills GDPR's 72-hour rule and HIPAA's breach notification requirement.
 - **Lessons Learned:** Updating policies and providing training reflects both legal compliance and the ethical principle of preventing future harm.
-